Privacy and Compliance

Data handling, controls and standards mapping

1. Data AIDDS handles

Agent activity logs can contain personal and confidential data (names, salaries, customer records inside payloads). The system therefore stores metadata first and payloads only when needed.

2. Privacy controls

Control	How
Data minimisation	Store tool, resource, data class, sizes and flags by default; do not store payload bodies
Masking	Where a payload sample is kept for forensics, mask personal data and cap its size
Secrets	Never log tokens or keys; store token_id only; secrets in a vault
Retention	Hot store 30 days, forensic snapshots 180 days, then delete; configurable per customer
Access control	RBAC: viewer (alerts), analyst (feedback, release), admin (manifests, retention)
Audit	Append-only log of manifest changes, approvals, releases and analyst actions
Encryption	TLS in transit, encryption at rest for event store and snapshots
Purpose limit	Event data used only for security detection and tuning

3. Legal and standards mapping

Framework	Relevant area	How AIDDS helps
OWASP Top 10 for LLM Applications	Prompt injection; excessive agency	Taint tracking, manifest limits, step-up approvals
NIST AI RMF (Govern, Map, Measure, Manage)	Risk management of AI systems	Manifests as governance; scenario map; evaluation metrics; graduated response
ISO/IEC 27001 controls	Access control, logging, incident handling	RBAC, audit log, runbooks
India DPDP Act, 2023	Personal data handling	Minimisation, masking, retention limits (confirm obligations with counsel)

This is a design mapping, not a compliance certification. Obligations depend on the deployment; have legal counsel review before handling real personal data.

4. Security of AIDDS itself

- Mutual TLS between gateway and services; signed manifests; append-only event log with integrity checks.
- Baseline poisoning: new baselines train only on traffic that passed review or came from shadow-mode-clean periods.
- Any LLM-based component (e.g. explanation text) gets only structured fields as input, never raw document text, to avoid injection into the detector.
- Rate limits and authentication on every API; dashboard actions are audited.

5. Responsible use

- AIDDS monitors agents, not employees. Do not use event data for staff performance monitoring.
- Explain restrictions to agent owners; allow appeal through analyst feedback.